

A Deterministic, CVSS–Environmental Method for FedRAMP VDR/VER Vulnerability Prioritization

Matthew Venne

Chief Technology Officer, stackArmor

July 2026

Abstract

The FedRAMP Vulnerability Detection and Response (VDR) and Vulnerability Evaluation and Reporting (VER) rules define *Potential Agency Impact* (PAIN, levels N1–N5) and a remediation–timeframe matrix, together with evaluation rules for likely exploitability and internet reachability. FedRAMP deliberately does *not* prescribe how to derive a PAIN level from an individual vulnerability on a specific asset. This memo argues that the missing classifier already exists, in standardized form, as the **Environmental metric group of CVSS**: the Confidentiality, Integrity and Availability *Requirements* (CR/IR/AR) and the Modified Impact Sub-Score inputs were designed precisely to re-weight a vulnerability’s impact by what is at stake in a given deployment. We preserve those impact values, Security Requirement multipliers, and aggregation form in a PAIN-specific normalization. We present a closed-form, reproducible mapping from FedRAMP’s requirements onto CVSS Environmental metrics, derive PAIN and the remediation deadline from it, and give fully worked calculations. The required architectural input is an *asset security-impact profile*: an uncapped CR/IR/AR vector whose three objectives remain independently assignable. A Cloud Service Provider (CSP) may derive that profile through a role-based asset-archetype catalog, direct per-objective assessment, or another governed and deterministic mapping. We recommend role-based archetypes as a strong starting point because they expose what a component does and why its requirements follow, but the taxonomy is an implementation choice rather than part of the formula. A scalar asset-value label is a permitted low-resolution shorthand, not a preferred model: it forces all three objectives to move together and retains less derivation evidence. An intended-use Security Requirements ceiling, derived independently from the offering’s and deploying agency’s confirmed federal information types, caps the profile per objective before scoring. This keeps the architectural assessment reusable across agency deployments while preserving the agency-specific C/I/A consequence. A reference architecture and a sample archetype-based scan complete the memo.

Contents

1	Status of This Memo and Terminology	2
2	Motivation: the gap between VDR/VER and the scanner	3
3	Key insight: FedRAMP’s requirements are CVSS Environmental metrics	4
4	The model	4
5	Before severity: resolve effective Security Requirements	5

6	Two threat inputs: EPSS and the CISA KEV catalog	6
7	The mathematics	6
7.1	Where this departs from standard CVSS scoring	10
8	Fail-safe behavior	11
9	Remediation: the VDR-TFR-PVR matrix	11
10	Worked examples	13
11	Mitigation and the PAIN Ladder	14
11.1	A semantic weakness in the mitigation ladder	15
12	Reference architectures and sample scans	19
12.1	Single-agency, Class C	19
12.2	Multi-agency, Class D	20
13	Relationship to CISA BOD 26-04	21
14	Assigning the asset security-impact profile	22
15	Applicability and the disposition via Vulnerability Exploitability eXchange (VEX)	24
16	Determinism, governance, and defensibility	25
17	Security Considerations	25
18	Conclusion	25
A	Example archetype-to-profile catalog	26
B	Remediation deadline matrices	27
C	Explicit design opinions (calibratable choices)	27
	Acknowledgements	30
	Normative sources	31

1 Status of This Memo and Terminology

This document is informational. It does not itself define a FedRAMP requirement; it specifies a standardized *method* for satisfying the existing VDR/VER requirements.¹

The key words MUST, MUST NOT, SHOULD, SHOULD NOT, and MAY are to be interpreted as described in RFC 2119.

¹The VDR and VER rules launched on 2026-06-24 as part of the FedRAMP Consolidated Rules for 2026 and apply to providers with FedRAMP certifications of any type.

PAIN

Potential Agency Impact, the FedRAMP N1–N5 rating of a finding.

CR/IR/AR

The CVSS Environmental Confidentiality / Integrity / Availability *Requirements* of an asset after any intended-use ceiling is applied.

Asset security-impact profile

The uncapped, independently assignable CR/IR/AR vector for an affected asset. A CSP may derive it from a role-based archetype, direct per-objective assessment, or another governed method.

Security Requirements ceiling

The per-objective C/I/A upper bound supported by the confirmed information types intended for the offering and affected agency scope.

Effective requirements

The per-objective minimum of the asset security-impact profile and the ceiling; these values enter the PAIN equation.

U The pre-cap complement-product aggregate derived from CVSS v3.1 impact values and Security Requirement multipliers.

MISS

The CVSS v3.1 Modified Impact Sub-Score, $\min(U, 0.915)$.

LEV / NLEV

Likely Exploitable Vulnerability / Not Likely Exploitable Vulnerability (a VER axis).

IRV / NIRV

Internet-Reachable Vulnerability / Not Internet-reachable Vulnerability (a VER axis).

VEX

Vulnerability Exploitability eXchange, a machine-readable assertion about whether a finding affects a specific product or deployment.

Class

The provider Certification Class (A–D): an operational assurance commitment selecting FedRAMP response tables, not a FIPS 199 category or a Security Requirements ceiling.

2 Motivation: the gap between VDR/VER and the scanner

A vulnerability scanner emits, per finding, a CVE identifier, a qualitative severity, and (often) a CVSS Base vector. FedRAMP VDR/VER, by contrast, asks the provider to answer a different question: *what is the potential impact on the agency if this vulnerability is exploited on this asset, and how quickly must it therefore be remediated?* The two are not the same. A “Low”-rated CVE on a crown-jewel datastore can carry more agency impact than a “High”-rated CVE on a throwaway sandbox.

FedRAMP supplies the *output* vocabulary (the PAIN buckets and the remediation matrix) and the *evaluation axes* (likely-exploitable, internet-reachable) but leaves the *classifier* — the function from (CVE, asset) to PAIN — to the provider. An ad-hoc or analyst-by-analyst classifier is neither reproducible nor defensible. This memo supplies a deterministic one.

3 Key insight: FedRAMP’s requirements are CVSS Environmental metrics

The central claim of this memo is that FedRAMP’s notion of “impact on the agency” maps, almost one-to-one, onto metrics that already exist in the CVSS v3.1 specification’s *Environmental* group. The Environmental group exists for exactly this purpose: to let the consuming organization re-score a vulnerability according to the criticality of the affected asset in *its* environment.

FedRAMP VDR/VER concept	CVSS mechanism that satisfies it
Asset data sensitivity / FIPS-199 C-I-A categorization	Security Requirements CR, IR, AR
Confirmed CSO and agency intended information types	Per-objective Security Requirements ceiling over the asset security-impact profile
Magnitude of potential agency impact	CVSS-derived pre-cap impact aggregate (<i>U</i>)
Likely exploitable (VER)	LEV: EPSS threshold / CISA KEV catalog membership
Internet reachable (VER)	IRV: per-finding payload reachability (companion method)
Single- vs. multi-agency blast radius	finding-specific affected-agency scope selects the PAIN tier
Provider Certification Class	operational-assurance tier selecting the remediation deadline table

Table 1: FedRAMP requirements fall directly onto CVSS Environmental metrics.

The consequence is that a conforming implementation need not invent a bespoke risk algebra. It need only (a) resolve each asset to an uncapped, independently dimensional CR/IR/AR security-impact profile, (b) resolve and apply the intended-use ceiling, and (c) evaluate the two VER axes. The arithmetic that turns the effective requirements into a defensible impact magnitude retains the published CVSS Environmental weights, Security Requirement multipliers, and complement-product aggregation form. PAIN then applies its own normalization and classification boundaries, as defined below.

4 The model

We define PAIN as a function of a *severity* term and a *scope* term:

$$\text{PAIN}(\text{finding}) = f(\text{SEVERITY}, \text{SCOPE}).$$

SEVERITY answers “how badly does this vulnerability’s impact land on the agency in this deployment?” — the CVE’s impact metrics re-weighted by the effective CR/IR/AR of the component on which each evidenced consequence lands. Ordinarily that component is the asset carrying the vulnerable code; a supported cross-component effect can make another component’s consequence

profile relevant. **SCOPE** answers whether the finding’s evidenced effect reaches one definite agency or several. It is a property of the finding in its deployed architecture, not merely a count of customers or data attached to the vulnerable asset. **SEVERITY** is mapped to a FedRAMP customer-effect word (Minimal, Narrow, Disruptive, Debilitating); the word and affected-agency scope together select the N-level.

IN PLAIN TERMS

See the whole method interactively. The PAIN & Remediation Playground shows how the inputs come together. Set the intended-use ceiling, choose an illustrative role-based mapping for the asset security-impact profile, observe the resulting effective CR/IR/AR vector, and then follow vulnerability impact, agency scope, reachability, likelihood, Certification Class, and mitigation through to the PAIN word, N-level, and remediation deadline. The playground is an explanatory companion; governed evidence and configuration remain the implementation’s source of record.

5 Before severity: resolve effective Security Requirements

An asset security-impact profile and an agency’s intended information use answer different questions. The profile describes what compromise of the component can do inside the CSO architecture. The intended-use ceiling describes the greatest federal consequence supported by the information types that the offering is designed and authorized to process and that the affected agency intends and is authorized to place there.

Before the PAIN Equation specifies the full upstream derivation from NIST SP 800-60 information types and FIPS 199 dimensional aggregation. For PAIN, its handoff is one vector per affected agency scope. Let $R_x(o)$ be asset x ’s uncapped security-impact-profile requirement for objective $o \in \{C, I, A\}$ and let $E_x(o)$ be the resolved intended-use ceiling. The effective requirement is:

$$R_x^{\text{eff}}(o) = \min(R_x(o), E_x(o)). \quad (1)$$

For a single-agency asset, E_x is that agency’s confirmed intended-use vector. For an asset that can affect several definite agencies, it is the per-objective maximum across those agencies. An agency elsewhere in the offering does not raise the ceiling of an asset that cannot affect it.

IN PLAIN TERMS

The asset profile says how important each security objective can be for the component inside the service. The ceiling says what federal consequences are actually in scope for the affected customer or customers. PAIN uses the lower value on each of C, I, and A. A High ceiling never makes a Low profile requirement High, and a High profile requirement never manufactures High agency impact when the intended use is Moderate.

The ceiling is dimensional. An overall FIPS 199 High system with category H/M/L retains H/M/L; the High label is not expanded to H/H/H. Generic free-text, upload, or integration capability does not add hypothetical information types that are outside the offering’s and agency’s intended, authorized use.

An implementation that has not declared a ceiling may continue with the uncapped asset security-impact profile as a conservative compatibility mode, because a ceiling can only lower a requirement. It **MUST NOT** describe that result as an evidenced, agency-specific intended-use derivation. Reports **SHOULD** retain the uncapped profile, its derivation method and source, the ceiling and its source when present, the effective vector, and whether any objective was capped.

6 Two threat inputs: EPSS and the CISA KEV catalog

IN PLAIN TERMS

Beyond the CVE’s own CVSS vector, the method pulls in exactly two facts about how each flaw behaves in the wild: how *likely* exploitation is (EPSS, a statistical score) and whether exploitation is *known to be happening* (the CISA Known Exploited Vulnerabilities catalog). Either one tightens the remediation *clock*; neither changes the PAIN *level*, which is driven by the CVSS vector and the asset’s requirements alone.

Two governed threat inputs feed the exploitability column:

- **EPSS probability** → statistical likelihood. A finding at or above the provider-selected threshold θ_{epss} is Likely Exploitable (LEV) (Section 9).
- **KEV membership** → confirmed exploitation. A CVE listed in the CISA KEV catalog is LEV regardless of its EPSS probability — observed exploitation in the wild overrides any statistical estimate. KEV membership also independently triggers the VDR-TFR-KEV remediation dates (Section 13), which run on CISA’s published schedule irrespective of the matrix.

How it plays in — three quick illustrations (Class C, single-agency):

- *KEV moves the clock (and starts a second one).* An N3 finding with EPSS 0.30 (below threshold) sits in the slow column: **128 days**. It appears in the KEV catalog: it becomes LEV — the deadline drops to **16 days** (internet-reachable) or 32 days (not) — and the CISA-published due date applies in parallel under VDR-TFR-KEV.
- *EPSS moves the clock statistically.* The same N3 finding, not in the KEV catalog but with EPSS 0.85 ($\geq \theta_{\text{epss}} = 0.50$), is LEV on likelihood alone and lands on the same 16/32-day clocks.
- *Neither present.* Sub-threshold EPSS and not in the KEV catalog (Section 9) → the finding is scored purely on its CVSS vector and stays in the slow column at its base tier.

7 The mathematics

IN PLAIN TERMS

This is the engine room — you can skim the equations and still follow the idea. Every flaw can hurt three things: **secrecy**, **correctness**, and **uptime**. For each, we multiply “how badly the flaw breaks it” by “how much this system depends on it,” then combine the three into a single damage score between 0 and 1. Finally we translate that score into a plain word. Bigger number = more damage. The only place human judgment enters is the three cut-points that decide where one word becomes the next.

The expected output is a PAIN level. The path is: compute an asset-specific impact scalar S from CVSS impact values and the asset’s CR/IR/AR; translate S into a customer-effect word (Minimal, Narrow, Disruptive, or Debilitating); then combine that word with the multi-agency flag to select N1–N5.

The numerical impact weights, Security Requirement multipliers, and aggregation form in Eq. (2) are taken from the CVSS v3.1 specification. Retaining the pre-cap aggregate, the High-centered normalization, the word thresholds, and the multi-agency mapping are this method’s additions; Section 7.1 delineates that boundary precisely.

WHAT THE SYMBOLS MEAN

- C, I, A — how badly *this flaw* breaks secrecy, correctness, and uptime (from the CVE’s CVSS vector). None / Low / High become 0 / 0.22 / 0.56.
- CR, IR, AR — how much *this system* needs secrecy, correctness, and uptime after Equation (1) caps the governed asset security-impact profile by the intended-use ceiling. Low / Medium / High become 0.5 / 1.0 / 1.5.
- U — the three dimensions combined into one pre-cap “damage to this system” aggregate.
- D_H — the maximum value of U , reached by all-High impacts at all-High requirements: 0.995904.
- S — U rescaled to a clean 0–1 range by D_H .
- W — the plain English word S maps to.
- m — does the system serve one agency (0) or many (1)? Resolved hierarchically from governed asset metadata.
- $\theta_1, \theta_2, \theta_3$ — the three cut-points where the word changes.

Impact metric weights. Each of the affected vulnerability’s effective Confidentiality, Integrity and Availability impact metrics (C, I, A) takes a weight. The initial values come from the CVSS Base vector; an evidence-gated Modified value can override them as described in Section 11:

$$C, I, A \in \{ \text{None} = 0, \quad \text{Low} = 0.22, \quad \text{High} = 0.56 \}.$$

Security Requirement weights. Each asset’s Requirement (CR, IR, AR) takes a multiplier:

$$\text{CR, IR, AR} \in \{ \text{Low} = 0.5, \quad \text{Medium} = 1.0, \quad \text{High} = 1.5 \}.$$

Pre-cap impact aggregate. The per-dimension impacts and requirements combine in CVSS’s bounded complement-product form: multiply the arithmetic complement on each dimension, then take the complement of that product:

$$U = 1 - (1 - C \cdot \text{CR})(1 - I \cdot \text{IR})(1 - A \cdot \text{AR}). \quad (2)$$

The PAIN denominator is the maximum value of that aggregate: all-High impacts at all-High requirements,

$$D_H = 1 - (1 - 0.56 \cdot 1.5)^3 = 0.995904. \quad (3)$$

We normalize to a unit scalar:

$$S = \frac{U}{D_H} = \frac{U}{0.995904} \in [0, 1]. \quad (4)$$

IN PLAIN TERMS

Reading Eqs. (2)–(4) step by step. Each of the three products — $C \cdot \text{CR}$, $I \cdot \text{IR}$, and $A \cdot \text{AR}$ — multiplies two facts: how badly the flaw damages one property (from the CVE’s vector) and how much this system depends on that property (from its requirements). A severe flaw on a system that does not care produces a small number; a modest flaw on a system that cares deeply produces a larger one. This is where “same CVE, different asset, different score” happens.

Subtracting each product from 1 flips it, within the arithmetic, from “damage dealt” to “share of that dimension left intact.” Multiplying the three complements and subtracting the result from 1 is a bounded complement-product aggregation. It has the same algebraic form as the probability that at least one of several independent events occurs, but the C/I/A weights are not probabilities and the method makes no statistical-independence claim. Unlike simply adding the three products, which could exceed 1, this

construction stays bounded and gives each additional affected dimension diminishing marginal weight. CVSS v3.1 turns this pre-cap value into MISS by applying $\text{MISS} = \min(U, 0.915)$. The value 0.915 is reached by all-High impacts at *Medium* requirements. High requirements multiply each affected dimension by 1.5, so one dimension can reach 0.84 and all three can reach 0.995904.

The original PAIN calibration also divided by 0.915. That created a methodology gap: assets with High requirements were measured against a Medium-requirement reference point, which artificially inflated their normalized PAIN scores relative to their position on the full attainable scale. Applying the CVSS cap also collapsed many distinct High-requirement states to the same value. The revised method retains U for PAIN and divides by the true all-High/all-High maximum, $D_H = 0.995904$. Now $S = 1.0$ means the maximum attainable PAIN impact aggregate. Published CVSS vectors and scores are never changed; this is a PAIN-specific classification path.

Severity word. S is bucketed into a FedRAMP customer-effect word by three cut points $(\theta_1, \theta_2, \theta_3)$:

$$W(S) = \begin{cases} \text{Minimal} & S < \theta_1 \\ \text{Narrow} & \theta_1 \leq S < \theta_2 \\ \text{Disruptive} & \theta_2 \leq S < \theta_3 \\ \text{Debilitating} & S \geq \theta_3 \end{cases} \quad \begin{matrix} \theta_1 = 0.28115159694107, \\ \theta_2 = 0.56230319388214, \\ \theta_3 = 0.933. \end{matrix} \quad (5)$$

The first two cut points are consequence anchors, not percentile targets: $\theta_1 = 0.28/D_H$ makes one High impact at a Low requirement Narrow, and $\theta_2 = 0.56/D_H$ makes one High impact at a Medium requirement Disruptive. The Debilitating threshold $\theta_3 = 0.933$ separates the strongest state without compound High-impact alignment ($S = 0.931993\dots$) from the weakest state with one High/High pair plus a second High impact at Medium-or-High requirement ($S = 0.933423\dots$). Thus a single High/High pair remains Disruptive; a qualifying compound alignment is Debilitating.

The additional component is a transparent proxy for vulnerability breadth, not a claim that one-dimensional catastrophic loss is unimportant. At least one H/H alignment remains necessary; the second High impact on a serious-or-catastrophic dimension approximates the broader class of vulnerability for which the reference method reserves *Debilitating*. The method deliberately does not use CWE ID as an input: CWE describes weakness root cause at varying abstraction and does not determine the C/I/A consequences of exploitation in a particular deployment. CWE remains useful for root-cause analytics and remediation outside the PAIN scalar.

The companion paper *Calibrating PAIN Without Abandoning CVSS* derives these anchors by exhaustively examining all 729 discrete impact/requirement states and then validates the resulting policy against operational datasets. An implementation MUST treat the thresholds as governed configuration rather than an in-band, ad-hoc setting.

Scope and the N-level. Let $m \in \{0, 1\}$ be the finding’s affected-agency flag: $m = 0$ when its evidenced effect is confined to one definite agency and $m = 1$ when it can affect several. Governed asset metadata, resolved from the most-specific applicable asset or containing-boundary value, supplies a practical baseline. The semantic input remains the scope of the finding’s *effect*. A finding on shared infrastructure can remain single-agency when tenant containment is demonstrated; a finding whose effect can traverse a shared control plane or dependency can be multi-agency even when the vulnerable process itself stores no agency data. The N-level follows from the word and

that affected-agency scope:

$$\text{PAIN} = \begin{cases} \text{N1} & W = \text{Minimal} \\ \text{N2} & W = \text{Narrow} \\ \text{N3} & W = \text{Disruptive}, m = 0 \\ \text{N4} & W = \text{Disruptive}, m = 1 \text{ or } W = \text{Debilitating}, m = 0 \\ \text{N5} & W = \text{Debilitating}, m = 1 \end{cases} \quad (6)$$

Scope selects consequences; it is not a generic severity multiplier. A security-boundary crossing has no independent PAIN weight. It matters when it changes the agency information, functions, assets, or missions that exploitation can affect; the objectives on which those consequences land; or the number of definite agencies exposed. Indiscriminately raising PAIN for every Changed-Scope vector, shared asset, or architectural edge would conflate topology with consequence and create noise. Likewise, asset count alone is not an impact measure: one database holding high-consequence information can matter more than many disposable replicas. Several affected assets matter when their combined effect changes the supported customer-effect word, not because their cardinality is multiplied into Equation (2).

Cross-component consequence attribution. When exploitation on one component produces a confidentiality, integrity, or availability consequence on another, the assessment follows the consequence. For example, if SQL injection in an application exposes records held by a database, the confidentiality consequence is governed by the database information and the applicable intended-use ceiling, not solely by the application process that contains the vulnerable code. The application does not automatically inherit the database’s complete security-impact profile: a read-only, tenant-scoped credential can project confidentiality without projecting database-wide integrity, availability, or multi-agency scope.

Stable architectural authority — such as an application role with durable, broad read access — should be represented in the upstream component’s governed, independently dimensional security-impact profile. A vulnerability-specific or conditional path can instead support an evidenced per-finding profile override. Data-flow, trust, privilege, and vulnerability metadata are relevant evidence for either decision. The present reference calculation still consumes one effective CR/IR/AR vector and one affected-agency flag per finding; it does not standardize automatic aggregation across an arbitrary graph of downstream assets. A future multi-target extension must define target resolution and consequence aggregation explicitly rather than introduce an uncalibrated scope factor.

7.1 Where this departs from standard CVSS scoring

Equation (2) is the expression inside the CVSS v3.1 Modified Impact Sub-Score (MISS), before CVSS applies its cap. Here $C/I/A$ denote the effective Modified impact values MC/MI/MA — or their inherited Base values when the Modified metrics are Not Defined. The metric weights, Security Requirement multipliers, and complement-product aggregation form are standard CVSS. A conformant CVSS calculation continues with $MISS = \min(U, 0.915)$; PAIN deliberately branches at U instead.

In the v3.1 specification, capped MISS feeds the full Environmental Score. For Modified Scope Unchanged, the specification multiplies MISS by 6.42; Modified Scope Changed uses a different impact expression. It then combines Modified Impact with Modified Exploitability, built from MAV/MAC/MPR/MUI, applies the Temporal multipliers E/RL/RC, caps the score at 10, and performs the prescribed rounding. MISS is not the specified final Environmental Score. PAIN does not carry that downstream machinery into its severity term. The decisions are explicit and separately governed.

We drop the exploitability half of the score. PAIN is Potential Agency Impact: the question is how badly the flaw lands if it fires, not how likely it is to fire. Exploitability is not discarded; it is routed to the axes FedRAMP built for it, the LEV/IRV remediation columns (Section 9), where threat and exposure are measured directly. CVSS’s exploitability metrics encode technical preconditions for exploitation; EPSS estimates exploitation probability, and KEV membership records observed exploitation. That separation is consistent with the exposure- and threat-based prioritization of BOD 26-04. Folding MAV/MAC/MPR/MUI back into the severity term would let exploitability influence both the row and the column. The seam is clean by construction: impact picks the row; exploitability and reachability pick the column.

We retain the pre-cap aggregate and normalize it instead of computing the 0–10 blend. Our deliverable is a classification — four words and five N-levels — so the scalar exists only to be bucketed. Equation (4) rescales U to the natural axis for drawing those lines: S is the fraction of the greatest value that the CVSS-derived aggregate can attain. This corrects the original method’s Medium-centered denominator and preserves distinctions among High-requirement states that the CVSS MISS cap would otherwise collapse. A threshold is not a claim that a vulnerability causes a physically measurable percentage of damage; the CVSS coefficients are not a ratio-scale measurement of harm. The division changes no ordering — it relabels the axis.

We do not repurpose CVSS Scope. The full Environmental formula branches on the Changed/Unchanged Modified Scope metric. CVSS Scope asks whether exploitation can affect resources governed by a security authority beyond the vulnerable component’s authority; it is not limited to sandbox or privilege-boundary escape, and Modified Scope can reflect the local environment. FedRAMP’s blast-radius concern here asks a different question: whether the finding’s supported effect reaches one agency or several. The multi-agency flag in Eq. (6) carries that concern directly, while the cross-component attribution above determines which consequence profile is relevant. Because these concepts are not semantically interchangeable, the CVSS Scope machinery is omitted rather than renamed or repurposed.

CVSS v4.0 makes impact location explicit without defining PAIN attribution. CVSS v4.0 retires the Scope metric and separately represents impact to the Vulnerable System (VC/VI/VA) and to Subsequent Systems (SC/SI/SA). “Subsequent System” is the term of art; it means a different

system whose security policy is violated as a result of exploitation, not simply another subcomponent touched by the data flow. FIRST’s user guidance therefore notes that SQL injection does not ordinarily create Subsequent-System impact when the application and database share credentials and operate within the same security scope. That CVSS classification does not erase the database’s agency consequence: PAIN may still need the database information context when the application’s authorized path exposes it. CVSS system-boundary semantics and PAIN consequence attribution answer related but different questions [CVSS40, CVSS40-UG].

The distinction is directionally useful but this memo does not yet prescribe a v4-native cross-system PAIN aggregation rule. Subsequent-System impact metrics should be retained as evidence for affected-asset and security-impact-profile analysis rather than silently discarded. Mapping a v4.0-only VC/VI/VA vector onto the present C/I/A inputs is a limited compatibility path; non-None SC/SI/SA, or deployment evidence that the consequence lands elsewhere, calls for explicit target review. A future extension may combine data-flow and trust evidence with Modified Vulnerable- and Subsequent-System impact metrics, but it must state how each consequence is associated with the effective requirements of the system on which it lands.

The result is not a conformant CVSS Environmental Score. It preserves CVSS’s impact values, requirement multipliers, and aggregation form, but retains the pre-cap U , routes exploitability and reachability to FedRAMP’s remediation columns, represents multi-agency blast radius explicitly, and applies PAIN-specific normalization and thresholds. Published CVSS vectors and scores remain unchanged. A reviewer can compare Eq. (2) with the expression inside the published MISS formula; every departure is enumerated above and in Appendix C.

8 Fail-safe behavior

Missing metadata **MUST NOT** *lower* PAIN. If a system has not been classified yet, the method assumes the worst rather than the best: an asset that carries no classification **SHOULD** resolve to a deliberately conservative default (e.g. CR/IR/AR all High), which scores loudly and surfaces the asset for classification rather than hiding it. “Unknown” is treated as “serious until proven otherwise” — silence never makes a problem look smaller than it is. Likewise, an absent intended-use ceiling leaves the resolved security-impact profile uncapped; it does not supply a guessed Low or Moderate value. This is conservative compatibility behavior, not evidence that the agency-specific derivation was completed.

9 Remediation: the VDR-TFR-PVR matrix

IN PLAIN TERMS

The N-level says *how bad*; this step says *how fast*. Two real-world facts tighten the clock: is the flaw actually being exploited (or very likely to be), and is the system reachable from the internet? More severe + more exploitable + more exposed = less time to fix. A lookup table turns those into a concrete deadline, stricter for higher-assurance providers.

Certification Class makes the provider’s assurance commitment operational. A Class B or Class C offering may support an agency use whose intended-use ceiling contains a High objective, but the High objective does not silently grant Class D response commitments. Unless a higher Class or tighter contract applies, the existing Class selects the vulnerability timeframe. The agency therefore needs both signals: PAIN states the potential consequence, while Class states the standard response commitment supplied for that consequence. *Before the PAIN Equation* specifies the

agency-disclosure, CSP-acceptance, and contract decision that must precede a High-objective use on Class B or Class C.

Availability is a specific case with additional operational evidence. When agency-authorized use produces an effective AR:H on a Class C offering, the agency and CSP should evaluate the service’s uptime commitment, RTO, RPO, failure-domain design, backup and restoration, failover behavior, dependencies, and recovery-test evidence. AR:H does not prescribe multi-region architecture or a particular uptime percentage. An adequate design and contract record may support the agency’s use of Class C without moving the offering to Class D, but it does not change the system’s FIPS 199 High category or lower AR:H. *Before the PAIN Equation* defines this availability-assurance case and its disposition choices.

The remediation deadline is selected by three values: the provider Certification Class, the PAIN level, and an exploitability *column* derived from the two VER axes:

$$\text{deadline} = M[\text{Class}][\text{PAIN}][\text{column}], \quad \text{column} \in \{\text{LEV+IRV}, \text{LEV+NIRV}, \text{NLEV}\}.$$

where, for a provider-selected EPSS threshold θ_{epss} (this memo uses 0.50):

$$\begin{aligned} \text{LEV} &= (\text{EPSS} \geq \theta_{\text{epss}}) \vee (\text{CVE} \in \text{KEV}), \\ \text{IRV} &= \text{the } \textit{finding} \text{ is internet-reachable (evaluated per vulnerability, not per asset).} \end{aligned}$$

DEFINITION

Internet reachability is a property of the *(vulnerability, asset)* pair, not of the asset alone. Per FRD-IRV, an internet-reachable vulnerability is one that “might be exploited or otherwise triggered by a payload originating from a source on the public internet” — explicitly including resources with *no direct internet route* that process payloads received indirectly; VER-EVA-EIR’s canonical example is SQL injection reaching a database on a private network through the application tier. The companion paper distinguishes the directly computable network branch from the transitive content and chained local-access branches. Its current operational profile is:

$$\text{IRV}_0(v, a) = \mathbb{1}[N(a) \cap X_N(v) \neq \emptyset] \vee (\mathbb{1}[J(v) = \text{confirmed}] \cdot C_0(a) \cdot (1 - P_0(v, a))) \vee G_0(v, a),$$

where $N(a)$ is the directly exposed network surface, $X_N(v)$ is the direct network surface required by the vulnerability, $J(v)$ is the reusable CVE-level indirect-trigger promotion, and $C_0(a)$ is the current coarse assertion that the component receives internet-derived content. $P_0(v, a)$ is a current, assessment- and ConMon-backed assertion that the relevant trigger or input-control class is prevented before vulnerable processing. Recurring DAST and remediation refresh that assertion; stale, out-of-scope, failed, or contradicted evidence sets P_0 to zero. $G_0(v, a)$ promotes an active AV:L finding when its canonical execution boundary contains an active, directly reachable upstream finding classified as a high-confidence chainable entry point; the downstream CVSS vector is unchanged and the upstream CVE and reason remain provenance. CVSS AV:L/A/P excludes a finding from the direct branch but does not prevent promotion into the applicable indirect or chained branch. The paper recommends this operational profile under today’s metadata conditions, under which reachability converges operationally toward direct accessibility plus known uncovered indirect triggers and governed chained-access promotions. A separate, non-normative full-information form shows how structured content trigger profiles and optional application-edge evidence can refine the result when publishers or provider-selected tools supply them. A separate, bypass-free IAP/VPN remote-access boundary can remove the backend’s direct path; application-level authentication is not an IRV/NIRV gate and instead informs LEV or attested mitigation. It lowers PAIN only when its enforced scope demonstrably reduces customer effect after successful exploitation. The full equations, optional extension model, and worked cases are specified in the companion paper *Internet Reachability at Scale under the FedRAMP VDR/VER Rules*.

Restricting the threat inputs to EPSS and the KEV catalog — and to nothing else — is itself a design opinion (see Appendix C). The day-valued tables are given in Appendix B. PAIN-1 carries no FedRAMP deadline.

10 Worked examples

IN PLAIN TERMS

The same formula, run by hand on realistic cases. Watch the *same* vulnerability land at very different N-levels depending only on which system it sits on — that is the entire point of the method.

We use C, I, A for impacts. Each example separately states the uncapped asset security-impact profile R_x , the intended-use ceiling E_x , and the effective CR/IR/AR vector $R_x^{\text{eff}} = \min(R_x, E_x)$ that enters PAIN. For concreteness, named roles in these examples use the illustrative archetype catalog in Appendix A; another conforming implementation can derive the same vectors without that taxonomy. All arithmetic follows Eqs. (2)–(6).

For reference, the severity word used in each example is assigned by:

$$W(S) = \begin{cases} \text{Minimal} & S < \theta_1 \\ \text{Narrow} & \theta_1 \leq S < \theta_2 \\ \text{Disruptive} & \theta_2 \leq S < \theta_3 \\ \text{Debilitating} & S \geq \theta_3 \end{cases} \quad \begin{aligned} \theta_1 &= 0.28115159694107, \\ \theta_2 &= 0.56230319388214, \\ \theta_3 &= 0.933. \end{aligned}$$

Example 1 — RCE on a crown-jewel datastore, multi-agency. $C = I = A = 0.56$ (High), $R_x = (H, H, H)$, $E_x = (H, H, H)$, and therefore $R_x^{\text{eff}} = (H, H, H)$, with $m = 1$. The ceiling does not bind:

$$\begin{aligned} U &= 1 - (1 - 0.84)^3 = 0.995904, \\ S &= 0.995904/0.995904 = 1.000 \Rightarrow W = \text{Debilitating}, \\ m = 1 &\Rightarrow \boxed{\text{N5}}. \end{aligned}$$

Example 2 — the same CVE and datastore under a Moderate ceiling. Keep the vulnerability, H/H/H datastore profile, and multi-agency scope from Example 1, but set $E_x = (M, M, M)$. The ceiling binds every dimension:

$$\begin{aligned} R_x &= (H, H, H), \quad E_x = (M, M, M), \quad R_x^{\text{eff}} = (M, M, M). \\ U &= 1 - (1 - 0.56)^3 = 0.914816, \\ S &= 0.914816/0.995904 = 0.918578 \Rightarrow W = \text{Disruptive}, \\ m = 1 &\Rightarrow \boxed{\text{N4}}. \end{aligned}$$

The ceiling alone makes Debilitating unreachable for this otherwise unchanged finding. The high-role profile remains reusable; in this example it is derived from an archetype, while the effective requirements reflect what the confirmed intended use puts at stake.

Example 3 — the same CVE on a sandbox, single-agency. $C=I=A=0.56$, $R_x = (L, L, L)$, and $E_x = (M, M, M)$. The ceiling is above the security-impact profile and therefore does not raise it: $R_x^{\text{eff}} = (L, L, L)$, with $m = 0$.

$$U = 1 - (1 - 0.28)^3 = 1 - 0.72^3 = 0.626752,$$

$$S = 0.626752/0.995904 = 0.629330 \Rightarrow \text{Disruptive} \Rightarrow \boxed{\text{N3}}.$$

Identical vulnerability, opposite ends of the matrix — the asset half of the score (CR/IR/AR) is doing the work.

Example 4 — availability-only DoS on a message backbone. A CVE with $C = 0$, $I = 0$, $A = 0.56$ (e.g. a parser DoS), on an asset with $R_x = (H, H, H)$ and an agency-supported $E_x = (M, M, H)$. The effective vector is $R_x^{\text{eff}} = (M, M, H)$, with $m = 0$ and EPSS = 0.76. The vulnerable parser sits on the inter-broker replication surface, which receives no internet-derived data, so the finding is not internet-reachable (surface-excluded under the companion model — had the flaw been in *message-payload* parsing it would be transitively IRV).

$$U = 1 - (1 - 0)(1 - 0)(1 - 0.84) = 1 - 0.16 = 0.84,$$

$$S = 0.84/0.995904 = 0.843455 \Rightarrow W = \text{Disruptive}, m = 0 \Rightarrow \boxed{\text{N3}}.$$

The single High/High pair $A \cdot \text{AR} = 0.84$ is serious but does not by itself clear the compound-impact Debilitating boundary. Remediation: LEV (EPSS ≥ 0.50) $\wedge$ NIRV; at Class C this is $M[\text{C}][\text{N3}][\text{LEV}+\text{NIRV}] = 32$ days. Note this finding may carry a *Low* vendor severity — PAIN is decoupled from the qualitative label.

Example 5 — information disclosure on a metadata-only service. $C=0.56$, $I=0$, $A=0$, on an asset with $R_x = (L, H, H)$ and $E_x = (M, M, M)$. The resulting $R_x^{\text{eff}} = (L, M, M)$ retains Low CR:

$$U = 1 - (1 - 0.28)(1)(1) = 0.28,$$

$$S = 0.28/0.995904 = 0.281152 \Rightarrow W = \text{Narrow} \Rightarrow \boxed{\text{N2}}.$$

A confidentiality leak on a service that holds only operational metadata is reconnaissance, not a debilitating breach — captured by the low CR.

11 Mitigation and the PAIN Ladder

IN PLAIN TERMS

FedRAMP does not demand that every flaw be *fixed* inside its deadline — it demands measurable vulnerability-response progress on schedule. Its tables express that progress through a PAIN row and a reachability/exploitability column. A provider can make the flaw hurt less if it fires (the row drops), or make it harder to reach or exploit (the column moves to a slower clock). An explicitly labeled proxy is also needed because FedRAMP asks providers to express mitigation progress through lower PAIN ratings even when the causal change is likelihood. The same control may therefore update the proxy and the separately required reachability or exploitability field. Every step must be backed by evidence somebody signed, every step is recorded, and no partial step may claim the residual risk is exactly zero — complete blocking is a different claim with its own disposition evidence.

FedRAMP’s response model is a ladder, not a binary. VER-RPT-VDT requires reporting the “time and Potential Agency Impact N-rating of each completed and evaluated reduction in Potential Agency Impact N-rating” and the “estimated time and target Potential Agency Impact N-rating of next reduction in Potential Agency Impact N-rating.” VDR-TFR-PVR likewise expresses timely partial mitigation as movement to a lower N-rating (Appendix B). The definitions are broader: FRD-PMV and FRD-FMV recognize a vulnerability as partially or fully mitigated when either its likelihood of exploitation *or* its PAIN has been reduced. A deterministic response method therefore needs both a governed way to recompute consequence when impact changes and a governed way to represent material likelihood reduction in the lower-N-rating workflow, whether or not the same reduction also changes a binary column.

11.1 A semantic weakness in the mitigation ladder

VER-EVA-EPA defines a vulnerability’s PAIN by the customer effect that exploitation could be expected to cause: Minimal, Narrow, Disruptive, or Debilitating, combined with affected-agency scope. Read literally, this is *conditional impact* — what happens if exploitation succeeds — rather than the probability that exploitation succeeds. Most compensating controls do not change that conditional consequence. A WAF rule, an authentication gate, network segmentation, exploit prevention, or sandbox enforcement usually changes whether the exploit reaches or completes on the vulnerable component. If the control fails and exploitation succeeds, the same agency consequence may remain. Controls that genuinely bound consequence — least privilege, tenant or data-store partitioning, read-only credentials, constrained egress that limits the result of code execution, or fault-tolerant design that limits outage — are real but form a narrower set.

That produces a potential weakness in the rule language. FedRAMP defines partial and full mitigation over *likelihood or PAIN*, but its timeframe and reporting workflow asks providers to express mitigation progress as a lower PAIN rating. Requiring every partial mitigation to prove lower conditional impact would deny credit to many of the controls most readily available after detection, especially when timely source remediation is impossible. Treating every likelihood control as if it literally changed impact would solve the workflow problem only by misstating the PAIN definition [VER, VDR, DEF].

Recommended reconciliation: retain PAIN and label the proxy. The original and current *consequence PAIN* should remain the estimate of customer effect conditional on successful exploitation. When remediation is not yet possible, an evidenced partial mitigation that materially reduces the local likelihood of successful exploitation SHOULD be eligible to produce a *residual-response PAIN proxy*: a lower N-level used to represent progress on the FedRAMP mitigation ladder even when the conditional consequence is unchanged. The proxy is not a claim that the affected information, mission, or agency scope became less important. It is a controlled translation of verified residual-risk reduction into the N-level vocabulary the response workflow requires.

The record SHOULD retain, side by side: the historical consequence PAIN; the current consequence PAIN; the residual-response proxy when used; the control and causal mechanism; the affected path and scope; evidence, validation time, and expiry; the size and calibration basis of the proxy reduction; and the remaining remediation plan. “One control equals one N-level” is not a rule. The reduction must be governed, proportional to the demonstrated likelihood change, and reversible when its evidence expires or the deployment changes.

One mitigation may update multiple required fields. FedRAMP requires providers to report PAIN, internet reachability, and likely exploitability as separate fields even though its mitiga-

tion definitions and lower-PAIN workflow overlap them. If one evidenced control materially reduces local likelihood and also changes IRV to NIRV or LEV to NLEV, that same control MAY support both the residual-response proxy and the updated column. This is correlated reporting of one mitigation through two FedRAMP-required outputs, not a claim that two independent controls or two independent reductions occurred. The records should reference the same control, evidence, scope, validation, and expiry so a reviewer can see the coupling. The evidence is counted once within each calculation; it is not duplicated as additional defense-in-depth, stacked again, or represented as a second independent residual factor. Neither output edits the published CVSS vector, EPSS probability, KEV status, or the independent CISA KEV deadline.

Complete blocking is a disposition, not another partial rung. This proxy applies only while residual exploitation risk remains. When current, scoped evidence demonstrates that the relevant exploit is completely blocked or neutralized, the finding moves to the full-mitigation/applicability path instead of taking additional proxy reductions. A signed VEX `not_affected` disposition can carry the applicable justification — for example, a bypass-free perimeter rule, prevention-mode EDR control, or enforced sandbox that blocks the specific exploit path — while retaining the would-be PAIN for audit and re-evaluation. Mere product presence, alert-only detection, incomplete rule coverage, or an untested control is not complete blocking. Remediation remains the separate state in which the vulnerability is eliminated and no longer detected.

The native impact lever is the other half of CVSS Environmental. Section 7 uses one half of the Environmental group, the Security Requirements (CR/IR/AR). The other half is the *Modified Base* metrics, which the CVSS specification provides precisely for capturing mitigations, configurations, and compensating controls present in a specific environment. The two halves split cleanly along the model’s own seam:

- **Consequence side — static unless architecture changes.** CR/IR/AR and affected-agency scope describe what is at stake. They never move merely to make a deadline.
- **Vulnerability side — dynamic.** The Modified impact metrics (MC/MI/MA) describe what the flaw can still do *here*, given the controls actually deployed. They are evidence-gated and move as mitigations land.

Recomputation runs through the same arithmetic — substitute the modified values for C, I, A in Eq. (2) — and the word, the N-level, and the deadline follow exactly as before. No new formula, no side channel.

Concrete row-movers. These are ordinary hardening actions, not magic wands; each has a defensible causal story for the dimension it lowers:

- Drop the vulnerable process to a non-root user with a read-only filesystem — the effective Integrity (and often Confidentiality) of an RCE falls.
- Scope the application’s database credential to a single schema — a SQL injection’s C/I falls: the payload still arrives, but it reaches less.
- Disable the vulnerable feature — the impact of a code path that cannot be invoked falls. (Removing the vulnerable code *outright* goes further and graduates to a VEX disposition; see below.)
- Confine egress — default-deny outbound rules break exploit chains that need a second stage.
- Rate-limit the affected endpoint — Availability impact falls for volume-dependent flaws.

High availability: automatic where the exploit cannot chase it. Verified redundancy is a legitimate Modified-Availability (MA) evidence class, and its facts are machine-checkable up front: replica count, *required* zone anti-affinity (a **preferred** rule is a scheduling hint, not a guarantee — verify the actual pod spread), a PodDisruptionBudget, and health-checked automatic restart. Where those facts hold, the credit applies *automatically*: MA High→Low, recomputed through Eq. (2), with the detected facts as the recorded evidence. The one carve-out is scoped by the companion reachability method: a finding that is *internet-reachable* does not take the automatic step, because IRV is precisely the statement that an attacker can deliver the trigger — and re-deliver it. Replication defends against *uncorrelated* failures; every replica in every zone runs the identical vulnerable code, and the load balancer obligingly delivers a repeated exploit to all of them. For that corner the step is still available, but with a per-finding citation stating why the trigger cannot be repeated at line rate (expensive to construct, rate-limited, state-dependent). Everywhere else — the majority of findings, where no internet path delivers the trigger — nothing is hammering the replicas, and redundancy covers exactly the accidental and one-shot failures it was built for. Adopting the automatic rule is a governed-configuration choice signed once (Appendix C), with the residual on record: an attacker already inside the boundary can still repeat a trigger against an NIRV finding. There is still no graduated zone schedule: the availability impact metric takes the values High, Low, and None, None is reserved for the VEX disposition path, so the ladder has exactly one rung here regardless of how many zones the deployment spans.

Worked example: Log4Shell egress-deny. In December 2021, most organizations’ first effective Log4Shell mitigation was not a WAF. One of the most widely deployed was default-deny egress — a NetworkPolicy or security-group change blocking outbound LDAP/RMI from application subnets. Log4Shell’s RCE requires a second-stage fetch of the malicious class from the attacker’s LDAP server, so blocking egress breaks the chain; but DNS-based exfiltration of environment variables (`{env:AWS_SECRET_ACCESS_KEY}`) remained observed in the wild — which is exactly why the Modified Confidentiality drops to Low and never to None. The arithmetic runs through Eqs. (2)–(6) unchanged. Base, with $C=I=A=0.56$ (High) on a $CR=IR=AR=1.5$ (High) multi-agency asset:

$$U = 1 - (1 - 0.84)^3 = 0.995904, \quad S = 1.000 \Rightarrow \text{Debilitating}, \quad m = 1 \Rightarrow \text{N5},$$

on the Class C LEV+IRV clock of **2 days** (Log4Shell is LEV because it is KEV-listed). With the evidenced egress-deny, $MC = MI = MA = 0.22$ (Low):

$$\begin{aligned} U &= 1 - (1 - 0.33)^3 = 0.699237, \\ S &= 0.699237/0.995904 = 0.702113 \Rightarrow \text{Disruptive}, \\ m &= 1 \Rightarrow \boxed{\text{N4}}. \end{aligned}$$

The N5 timeframe is satisfied by the reduction, the reduction is reported under **VER-RPT-VDT**, and work proceeds on the N4 clock. The evidence is the NetworkPolicy object snapshot and enforcement evidence showing the egress path removed; optional flow or graph evidence can help bind that control to the workload. One clock is untouched: Log4Shell is a KEV, so the **VDR-TFR-KEV** remediation date runs independently of any reduction.

Guardrails. The lever only ever lowers apparent risk, so it carries the same governance as the disposition overlay of Section 15:

1. A modification MAY only *lower* a dimension on cited, signed evidence, and MUST be re-evaluated whenever the control it relies on changes. The evidence bar scales with the PAIN being reduced.

2. A modification MAY lower High to Low but MUST NOT lower any dimension to None. Claiming *zero* impact is an applicability claim, and it travels as a VEX disposition (`not_affected`), not as a metric modification.
3. The audit trail records base → modified per dimension with the evidence references, mirroring the retained-PAIN pattern: the pre-mitigation rating stays on record and the reduction is attributable and reversible.

The rest of the menu, from the same incidents. The guardrails are not hypothetical — each has already played out in public:

- **Code removal (Log4Shell).** Apache’s own interim recommendation removes the vulnerable class from the jar entirely:

```
zip -q -d log4j-core-*.jar org/apache/logging/log4j/core/lookup/JndiLookup.class
```

In this model that claim travels as a VEX disposition (`vulnerable_code_not_present`) evidenced by the modified jar hash — not as a Modified-impact claim (guardrail 2).

- **Config kill-switch, and the re-evaluation lesson (Log4Shell).** The JVM flag `-Dlog4j2.formatMsgNoLookups=true` was initially treated as a complete mitigation — until CVE-2021-45046 showed non-default configurations (Thread Context Map patterns) where lookups still fired, and the flag was downgraded to insufficient. That is guardrail 1 playing out in the real world: mitigations carry timestamps and are re-evaluated when the facts change; a one-time silent suppression would have outlived its justification.
- **regreSSHion (CVE-2024-6387).** The published mitigation is one line of `sshd_config`: `LoginGraceTime 0`, closing the pre-authentication RCE race at the cost of a connection-exhaustion DoS risk — a mitigation that *trades* impact dimensions (Modified C/I fall, Modified A is retained or worsens), and one no WAF could ever address.
- **Spring4Shell (CVE-2022-22965).** Spring’s interim workaround was a `@ControllerAdvice` restricting the data binder’s `disallowedFields` (`"class.*"` and friends) — an application-configuration mitigation shipped while framework upgrades were scheduled.

Column moves: the other axis. Reachability and exploitability mitigations do not touch the impact metrics at all — they move the finding’s *column*. Network segmentation that verifiably cuts the payload path, or a current prevention assertion under the companion model, can flip IRV to NIRV; a qualifying remote-access boundary (the companion model’s Gate 3) can flip IRV to NIRV. The matrix supplies a longer clock when either binary classification changes. The textual hook is FRD-PMV/FRD-FMV: FedRAMP defines mitigation over *likelihood or PAIN*, and an evidence-backed reachability or exploitability reduction is the likelihood half. The column move and the separately labeled residual-response proxy may coexist because FedRAMP asks for both current column fields and lower-N-rating mitigation progress. They must carry the same provenance and be identified as correlated outputs of one control. Where the mitigation materially reduces local likelihood but crosses neither binary boundary, the proxy can still represent that progress. In neither case does the proxy pretend that conditional impact changed.

Where the ladder ends. The descent is bounded, not endless. It terminates in one of four states: *remediation*; *full mitigation* (FRD-FMV: the vulnerability “will still exist (with negligible risk) until it has been remediated,” the remaining remediation handled in routine operations per VDR-TFR-RMN, KEVs excepted); *PAIN-1*, which carries no timeframe (Appendix B) and likewise returns the finding to routine operations; or *formal acceptance* — VER-TFR-MAV requires categorizing any vulnerability that is not or will not be fully mitigated or remediated within 192 days of evaluation as an accepted

vulnerability, tracked on the accepted track of Section 15. It is no coincidence that 192 days is also the largest cell in the timeframe matrix: the grid and the acceptance boundary meet by construction. Nor does each rung demand a fresh mitigation. Each step lands on a strictly longer clock (at Class C, LEV+IRV: $2 \rightarrow 4 \rightarrow 16 \rightarrow 48$ days), so the common pattern is a single mitigation that buys schedule, followed by remediation on the longer clock — or, where remediation is genuinely impossible, acceptance at the 192-day boundary rather than an indefinite treadmill.

WAF realism. A WAF virtual patch is one item on this menu, not the presumed answer. VER-EVA-EIR calls payload interception “the simplest way” to prevent exploitation — not the expected way. Narrow, CVE-specific virtual patches are often practical (blocking Log4Shell’s JNDI lookup strings); generic rules — say, parameterized SQL-injection signatures across a real API surface — carry false-positive risk to legitimate customer traffic, and the claimed mitigation **MUST** be re-validated whenever the rule set changes. The incident record above bears this out: under real deadline pressure, the mitigations that actually shipped were configuration flags, code removal, privilege and egress confinement, and binding restrictions — surgical, testable, and zero risk to customer traffic — while the WAF rule was the fallback for the workloads that could not be touched (appliances, vendor binaries). That is precisely its position in this method. The companion reachability paper develops the corresponding posture recommendation: keep the finding IRV and attest the perimeter mitigation via signed VEX rather than reclassifying reachability on WAF evidence.

12 Reference architectures and sample scans

12.1 Single-agency, Class C

Figure 1 shows a representative deployment using the optional role-based archetype method to derive each component’s security-impact profile. Table 2 shows the corresponding per-finding output for a fictional Class C, single-agency offering. The examples deliberately reuse the catalog in Appendix A; the PAIN formula does not require those labels. The PAIN column is computed by the method above; the Classical Severity column is the scanner’s qualitative rating, shown to make the decoupling explicit.

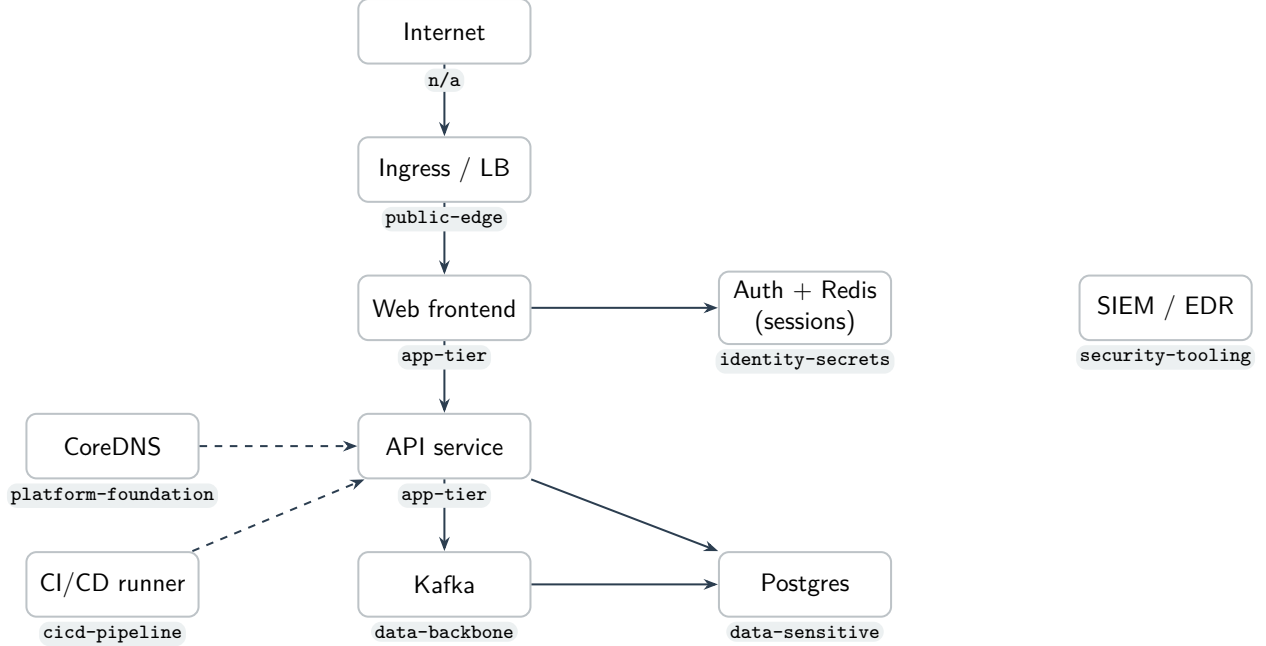


Figure 1: Archetype-based reference implementation; each node carries an optional `asset-archetype` tag that resolves to an asset security-impact profile.

CVE	Resource (archetype)	Classical	EPSS	IRV	PAIN	Remediation
CVE-2026-xxx1	ingress (public-edge)	CRITICAL	0.97	yes	N4	4 days
CVE-2026-xxx2	payments-db (data-sensitive)	CRITICAL	0.94	yes (t)	N4	4 days
CVE-2026-xxx3	redis (identity-secrets)	HIGH	0.50	no	N4	8 days
CVE-2026-xxx4	kafka (data-backbone)	LOW	0.76	no	N3	32 days
CVE-2026-xxx5	web (app-tier)	MEDIUM	0.20	yes	N3	128 days
CVE-2026-xxx6	coredns (platform-foundation)	MEDIUM	0.08	no	N2	192 days

Table 2: Sample VDR scan output (fictional data, placeholder CVE IDs; Class C, single-agency). PAIN is computed from the effective CR/IR/AR after the intended-use ceiling is applied and the CVE impact vector; the deadline is $M[C][PAIN][column]$. The IRV column is evaluated *per finding* via the companion finding-level model; (t) marks transitive payload exposure. CVE-2026-xxx2 is FedRAMP’s canonical case: a content-triggered (SQL-injection-class) finding on a datastore that is not internet-accessible is still IRV because this sample assumes no current P_0 prevention assertion, tightening the deadline to 4 days. CVE-2026-xxx4 — a *Low* vendor severity that yields N3 (a single availability High/High alignment; Example 4) — stays NIRV because its vulnerable parser sits on the inter-broker replication surface, which receives no internet-derived data.

12.2 Multi-agency, Class D

Figure 2 is a shared, multi-tenant platform serving *several* agencies at the highest assurance (Class D). Its shared components carry more than one agency’s data, so they are tagged multi-agency (here via the cluster default, with single-agency tenant workloads tagged as the exceptions). Table 3 shows the result: the same families of flaws now remediate in *hours*.

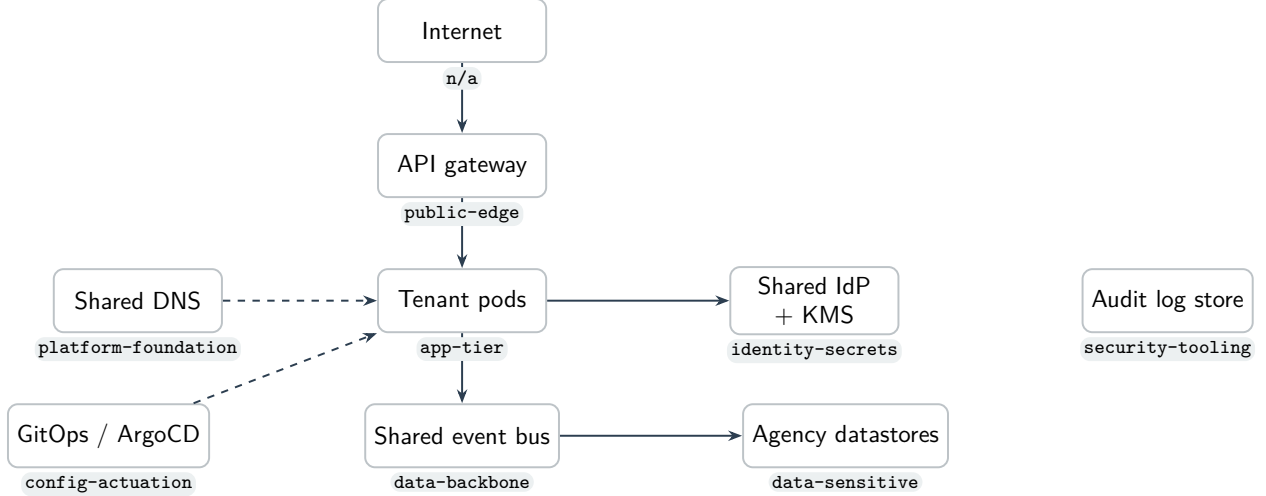


Figure 2: Multi-agency reference architecture; shared components serve several agencies and are tagged multi-agency.

CVE	Resource (archetype)	Classical	EPSS	IRV	PAIN	Remediation
CVE-2026-yyy1	gateway (public-edge)	CRITICAL	0.90	yes	N5	12 hours
CVE-2026-yyy2	shared-idp (identity-secrets)	CRITICAL	0.95	no	N5	1 day
CVE-2026-yyy3	event-bus (data-backbone)	LOW	0.80	yes (t)	N4	2 days
CVE-2026-yyy4	agency-db (data-sensitive)	HIGH	0.40	no	N5	8 days
CVE-2026-yyy5	tenant-pod (app-tier)	MEDIUM	0.10	no	N3	64 days
CVE-2026-yyy6	shared-dns (platform-foundation)	MEDIUM	0.05	no	N2	192 days

Table 3: Sample VDR scan output (fictional data, placeholder CVE IDs; Class D, multi-agency). Multi-agency scope escalates Disruptive/Debilitating findings, and Class D carries the tightest deadlines — an internet-facing exploitable flaw on the shared edge remediates in **12 hours** (CVE-2026-yyy1). CVE-2026-yyy3 shows a *Low* vendor severity at N4 remediating in **2 days**: a content-triggered DoS in message-payload parsing on the shared backbone is transitively internet-reachable (t) through the tenant pods, even though the bus itself is not internet-accessible; the sample assumes no current P_0 assertion covers that trigger. A confidentiality leak on shared DNS (CVE-2026-yyy6) stays N2 and NIRV — “Narrow” does not escalate with scope.

13 Relationship to CISA BOD 26-04

The VDR/VER rule is FedRAMP’s implementation of CISA Binding Operational Directive 26-04.² FedRAMP adopts the directive’s *philosophy* — move remediation prioritization off raw CVSS base scores and onto exploitability and mission impact — but substitutes its own instruments for the directive’s pillars:

²CISA, *Binding Operational Directive 26-04*, 2026-06-10. The VDR rule lists it as the mandating authority, with optional adoption from 2026-07-04, obtain/maintain from 2026-12-07, and grace ending 2027-03-07.

BOD 26-04 pillar	FedRAMP VDR/VER instrument	Status
SSVC drives prioritization	PAIN (Potential Agency Impact, N1–N5)	SSVC not named; PAIN replaces it
VEX communicates exploitability	LEV (exploitation) + disposition (§15)	VEX not named; role split across LEV and VER disposition
CSAF machine-readable advisories	VER JSON reporting (§15)	format unspecified; CycloneDX VEX proposed (companion)
KEV catalog due dates	VDR-TFR-KEV (defers to CISA dates)	retained intact; also consumed as a LEV input
(none)	IRV/NIRV and Certification Class	added as timeframe axes

Table 4: FedRAMP keeps BOD 26-04’s intent but swaps SSVC → PAIN and VEX → LEV+disposition, retains KEV, and adds reachability and Class.

The first row is the deviation that shapes this memo. Because FedRAMP chose *PAIN* rather than SSVC, an SSVC-based prioritizer does not by itself satisfy the rule — and FedRAMP publishes PAIN’s *output* buckets and the timeframe table but not the *classifier* that produces an N-level. That gap is exactly what Section 7 fills, which is why this method is expressed in CVSS Environmental terms (the missing input was PAIN, not an exploitability score) rather than in SSVC. The directive’s other instruments retain narrower roles: this memo consumes the *KEV catalog* directly as one input to LEV (Section 9) — arguably a cleaner story than substituting for it, since BOD 26-04’s own exploitation instrument is kept intact rather than replaced by a derived signal — while VEX carries the post-detection *disposition* of each finding (Section 15). Neither SSVC nor VEX is mandated by the rule by name.

14 Assigning the asset security-impact profile

IN PLAIN TERMS

The PAIN formula requires an uncapped, three-dimensional CR/IR/AR profile for each affected asset; it does not require a particular taxonomy or metadata key. A CSP can assign the three objectives directly, derive them from a role-based archetype catalog, or use another governed mapping. Whatever the method, it must preserve the ability to express mixed vectors such as H/M/L and retain why each objective was assigned.

The model in Section 7 is only as good as the CR/IR/AR assignment that feeds it. A conforming implementation **MUST** resolve every affected asset to an asset security-impact profile, **MUST** support independent CR, IR, and AR assignments, and **SHOULD** retain the derivation method, source evidence, objective-specific rationale, policy version, and any override. This is the normative input contract. How a CSP produces the vector is provider-governed.

Role-based archetype mapping. One strong derivation method is to sort systems into a short list of *archetypes* — a database, a login service, a cache, a message bus, and so on. Each archetype maps to a pre-filled security-impact profile. The mapping asks narrow questions that architecture and inventory can help verify: does the asset control other systems, hold credentials, authenticate users, store sensitive data, or support several services?

A reviewer can then check both parts of the decision: whether the asset performs the stated role and whether that role maps to the right CR/IR/AR requirements inside the CSO. Archetypes do not remove human judgment, but they make the architectural rationale visible, reusable, and harder to manipulate. Not every asset will fit cleanly, so a CSP using this method MAY define custom roles, adjust its mappings, or make an evidenced per-asset override. The catalog in Appendix A is one example derivation, not the PAIN classification standard.

Direct per-objective assignment. A CSP MAY instead assign CR, IR, and AR directly from a governed component assessment. Direct assignment is fully conforming when the three objectives remain independently selectable and the evidence and rationale are retained. It is especially useful where a component does not fit a reusable role class or where the provider already maintains an authoritative, objective-specific asset classification. The method does not force CR, IR, and AR to be equal.

A simpler but less informative conforming implementation is to tag assets directly with a scalar `asset-value`. Under that approach, H or High maps to static CR:H/IR:H/AR:H; M, Medium, or Moderate maps to CR:M/IR:M/AR:M; and L or Low maps to CR:L/IR:L/AR:L. This schema is easy to implement and may be sufficient for smaller or more homogeneous estates. Its tradeoff is that it states the conclusion without recording why: every security requirement moves together, and the label does not separately explain the asset’s confidentiality, integrity, and availability needs. A scalar value SHOULD NOT be the only assignment interface: an implementation should permit an asset to graduate to an independent vector without changing the scoring method.

The archetype catalog in Appendix A illustrates one way to derive asset security-impact profiles. A conforming implementation does not have to use it, use the word “archetype,” or expose an `asset-archetype` key. If a CSP does use the catalog, it MUST derive assignments from the roles, trust relationships, control functions, and consequences inside its own CSO architecture. Each CSP SHOULD own and justify its mappings. The agency-specific FIPS 199 and information-type context belongs in the separately governed Security Requirements ceiling. Two providers can legitimately derive different profiles for the same software because it performs different roles; two agency deployments can retain the same uncapped profile while resolving different effective requirements.

For the illustrative role-based catalog, the classification rule we recommend is *control-plane lens first*: if an asset can deploy, orchestrate, hold cross-estate credentials, or actuate configuration, classify it by that control function regardless of the data it stores; otherwise classify by the data it holds. The same physical software lands in different archetypes by role — an in-memory store used as a cache is `app-tier`, the same software used as a session/token store is `identity-secrets`, and used as a job broker is `data-backbone`.

For Kubernetes estates, the multi-agency flag can be resolved most-specific-first: workload label, then namespace label, then cluster default. Other deployment models should apply the same rule to their own asset, boundary, and provider-default metadata.

15 Applicability and the disposition via Vulnerability Exploitability eXchange (VEX)

IN PLAIN TERMS

Scoring says how bad a finding is and how fast to fix it. But a scanner's hit is not yet a confirmed problem: the flagged code may not be present, may never run, may need a configuration nobody set, or may already be neutralized by a control. Deciding which is the *disposition* step — and it can only happen *after* a finding is detected, because you cannot pre-judge factors specific to a vulnerability you have not yet seen. This section places that step in the method and names the kind of artifact that records it: VEX.

The PAIN derivation in Sections 7 and 9 is deterministic: given the asset's CR/IR/AR, the VER axes, and the configured thresholds, the N-level and deadline follow by formula. Disposition answers a different question: whether the scanner finding is actually exploitable in this running environment. That requires evidence about the specific vulnerability and deployment — for example, whether the affected code is present, reachable, configured, or already neutralized by a compensating control. The analysis may be automated, but it happens after detection because those facts are finding-specific.

Where FedRAMP requires it. VER requires three things relevant here: evaluate whether a scanner finding is real, record the per-finding disposition, and track vulnerabilities that are accepted rather than remediated. The FedRAMP clauses behind those duties are VER-EVA-EFP, VER-EVA-AIA, VER-RPT-VDT, and VER-TFR-MAV/VER-RPT-AVI. VER makes the disposition step mandatory, but it does not prescribe a carrier format. The *Vulnerability Exploitability eXchange* (VEX) is a standardized, machine-readable, signable artifact for carrying those assertions.

Two outcomes. A disposition resolves a finding onto one of two tracks:

- **Not truly affected** — suppressed with a machine-readable *justification* (component or vulnerable code not present, code not reachable, exploitation requires a configuration that is not set, or a compensating control is already in place).
- **Affected but remediation will be late** — under VER's tight clocks a provider MAY be unable to patch before the deadline; the finding is recorded as *accepted*, with an attested mitigation and a planned response.

A disposition overlay, not a re-score. Disposition does not change the arithmetic. Every detected finding is scored as in Section 7; a VEX assertion then moves the finding from the active remediation queue into a suppressed or accepted set *while its computed PAIN is retained*. Keeping the would-be PAIN on record makes every suppression auditable and reversible — the safeguard the Security Considerations (Section 17) call for: a downgrade by disposition is visible, attributable, and can be revisited if the assertion is later contradicted.

A distinct axis. Applicability (VEX) is orthogonal to exploitation-likelihood (LEV, Section 9). LEV asks *how likely is this vulnerability to be exploited in the wild*; VEX asks *is this product, as deployed, affected at all*. A finding can be likely-exploitable in general yet **not_affected** here because the vulnerable path is unreachable. The two are evaluated independently and **MUST NOT** be collapsed into one.

Guardrails. Because a disposition only ever *lowers* apparent risk — and the more so once the determination is automated — the governing controls matter as much as the analysis. Absent sufficient evidence a finding **MUST** remain affected, honoring **VER-EVA-AIA**; and the evidence required to suppress **SHOULD** scale with the retained PAIN, so a KEV-class, internet-reachable, high- N finding demands far stronger corroboration — and human review — than a low- N internal one. Every disposition **SHOULD** cite the evidence it rests on and be signed, so it is reproducible and attributable; and it **SHOULD** carry a timestamp and be re-evaluated when the image, configuration, or control it relied on changes, so a suppression cannot outlive the condition that justified it.

16 Determinism, governance, and defensibility

- **Determinism.** Given the same (CVE vector, effective security-impact profile, VER axes), the method yields the same PAIN and deadline on every run and for every analyst.
- **Governed asset inputs.** An asset needs an uncapped security-impact profile, and each finding needs an affected-agency scope. The profile may be assigned directly or resolved from governed metadata such as an archetype; the intended-use ceiling is resolved separately. Finding-specific cross-component evidence may identify a different consequence context without changing the published CVE vector.
- **Governed calibration.** The High-centered PAIN normalization, word thresholds (Eq. (5)), and EPSS threshold are governed parameters and **MUST** live in governed configuration, not in ad-hoc cluster state.
- **Auditability.** Each finding can carry the full derivation: the uncapped profile, its derivation method, source and rationale, the ceiling, effective CR/IR/AR, S , the word, the scope, and the selected matrix cell.

17 Security Considerations

The method trusts each asset’s resolved security-impact profile: if someone understates a critical component, its flaws will look smaller than they really are. Its integrity therefore depends on the trustworthiness of the profile derivation and the VER axes (EPSS / KEV membership / reachability). Any assignment or override that improperly *lowers* a profile is a downgrade attack; the fail-safe default and governed calibration mitigate accidental under-classification, but profile inputs **SHOULD** be controlled like any other security setting. Role-based archetypes can narrow but do not eliminate this risk: a claimed role can be compared with architecture, data flows, identity permissions, and inventory. Direct per-objective assignment can be equally defensible when it retains that evidence; a scalar value label ordinarily provides less to check. Finally, the method does not detect vulnerabilities; it prioritizes the output of a scanner and inherits that scanner’s coverage and accuracy.

18 Conclusion

FedRAMP VDR/VER specifies the vocabulary and the axes of vulnerability prioritization but leaves the classifier unspecified. That classifier need not be invented: the CVSS Environmental metric group already encodes “re-weight impact by what is at stake,” which is precisely the agency-impact question. By assigning each asset an independently dimensional security-impact profile

and evaluating the two VER axes, a provider obtains a deterministic, auditable, and standards-grounded PAIN and remediation deadline for every finding. A CSP may use direct per-objective assessment, a governed classification system, or another deterministic method. We recommend role-based archetypes as a strong starting point because they record what an asset does and expose how its requirements were derived. A scalar asset-value label remains a conforming fallback, but it forces CR/IR/AR to move together and records the conclusion with less evidence behind it. We offer the example archetype catalog not as a required taxonomy or standard but as one existence proof.

A companion proposal, *A Finer Exploitability Gradation (VLEV) for FedRAMP VDR/VER*, separately explores tightening the exploitability axis. It is kept out of this memo deliberately: this memo’s scope is meeting FedRAMP’s requirements as they stand today, not changing them. A second companion, *A CycloneDX VEX Profile for FedRAMP VDR/VER Disposition and Response*, specifies the machine-readable format for the disposition step of Section 15.

A Example archetype-to-profile catalog

Illustrative only (see Section 14). This catalog demonstrates one role-based way to derive asset security-impact profiles. A CSP may use it as a starting point, define a different taxonomy, assign the three objectives directly, or use another governed method.

Example archetype	Lens	CR	IR	AR	Typical members
cicd-pipeline	control	H	H	H	build/deploy runners, artifact signing, registries
orchestrator	control	H	H	H	control plane, etcd, scheduler, coordination
config-actuation	control	H	H	H	IaC/GitOps, schema registry, admin/migration
identity-secrets	control	H	H	H	IdP/SSO, KMS, secrets managers, session stores
security-tooling	control	H	H	M	scanners, SIEM, EDR, runtime security
change-record	control	M	M	M	ITSM/ticketing (record only)
platform-foundation	control	L	H	H	DNS, NTP, service discovery, L4 internal LBs (metadata only)
data-sensitive	data	H	H	H	PII/CUI datastores
data-backbone	data	H	H	H	payload queues and brokers, the system-of-record DB
telemetry-backbone	data	M	M	M	metrics/trace pipelines, telemetry queues, event buses carrying no agency payload
app-tier	data	M	M	M	stateless services, APIs, UIs, caches
batch-analytics	data	M	M	L	ETL, reporting, analytics jobs
public-edge	data	M	M	H	TLS-terminating L7 edge: ingress, API gateways, public web
passthrough-edge	data	L	L	H	L4/SNI passthrough load balancers (no TLS termination)
internal-tooling	data	L	L	L	dashboards, metrics/log agents
dev-test	data	L	L	L	non-production
unclassified	—	H	H	H	fail-safe default for untagged assets

Three assignments deserve their reasoning on the record. First, **data-backbone** is reserved for components that carry agency payload data; a bus that moves only metrics, traces, and heartbeats is **telemetry-backbone**, one grade lower on every dimension. Routing payload data through a telemetry bus is a misclassification finding, not a reason to keep every bus at High. Second, the availability grades split deliberately between the edge and the application tier. **public-edge** keeps AR High because a CVE-grade denial of service hits every replica at once—redundancy defends against hardware failure, not against a flaw shared by the whole class—and an edge-class outage closes the front door for every user. **app-tier** sits at Medium because its blast radius is one service degrading. An availability-only High CVE is Disruptive in both cases under the compound-impact boundary, but High AR gives the edge the larger scalar and can combine with a second affected dimension to cross into Debilitating. Third, the edge itself is split by what it does with traffic. **public-edge** names the TLS-terminating L7 edge — in practice, almost every modern ingress, gateway, or public web front — and carries CR and IR at Medium: a terminating edge holds private keys and session material and sees every payload in flight, so a memory-disclosure flaw there is key and token theft, not reconnaissance. **passthrough-edge** is the deliberate opt-in for an edge that never terminates — an L4 or SNI passthrough that routes payload but holds none — where CR and IR genuinely drop to Low. The stronger values sit on the default-sounding name on purpose: an edge tagged **public-edge** out of habit should overrate, not underrate. Where termination is handled by a managed cloud load balancer whose keys never enter the boundary, the passthrough tag is the honest one — the terminating component sits on the provider’s side of the shared-responsibility line.

B Remediation deadline matrices

Days; 0.5 = 12 hours. Columns in order LEV+IRV / LEV+NIRV / NLEV. PAIN-1 has no FedRAMP deadline (any class). The day counts below are reproduced *verbatim* from FedRAMP’s published **VDR-TFR-PVR** table;³ Classes A and B share one schedule. The only provider-side choice here is which Certification Class the offering commits to — not the numbers.

	Class A / B			Class C			Class D		
PAIN	L+I	L+N	NLEV	L+I	L+N	NLEV	L+I	L+N	NLEV
N5	4	8	32	2	4	16	0.5	1	8
N4	8	32	64	4	8	64	2	8	32
N3	32	64	192	16	32	128	8	16	64
N2	96	160	192	48	128	192	24	96	192

Note: Values are days measured from *completed evaluation* (VDR-TFR-PVR runs its timeframes from evaluation, not detection) within which the finding SHOULD be remediated, fully mitigated, or at least partially mitigated to a lower PAIN rating; 0.5 represents 12 hours.

C Explicit design opinions (calibratable choices)

Everything in this section is a *judgment call* we made — not something FedRAMP or CVSS dictates. We collect them in one place so reviewers can challenge each one, and so any adopter

³FedRAMP, *Vulnerability Detection and Response (VDR)*, provider rule, requirement VDR-TFR-PVR. Generated markdown pinned at FedRAMP/2026-markdown@2a75592 (commit of 2026-06-24); accessed 2026-06-27. Mandated by CISA BOD 26-04; FedRAMP may revise the values.

knows exactly which dials are theirs to turn. None of these is load-bearing for the *method*; they are the parameters the method runs on. Each item below names the value we use, why, and the fact that an implementation MAY change it.

1. **High-centered PAIN normalization**, $D_H = 0.995904$. PAIN retains the pre-cap aggregate U and normalizes it by the maximum attainable all-High-impact/all-High-requirement value (Eqs. 3–4). The initial publication used the CVSS MISS cap, 0.915, as both cap and denominator. Because 0.915 represents all-High impacts at *Medium* requirements, that baseline overstated where High-requirement states sat on PAIN’s full attainable scale and erased distinctions above the cap. The High-centered denominator closes that methodology gap without changing a published CVSS vector or score.
2. **PAIN word thresholds** $(\theta_1, \theta_2, \theta_3) = (0.28115159694107, 0.56230319388214, 0.933)$. These cut points turn S into Minimal/Narrow/Disruptive/Debilitating (Eq. 5). The initial publication began with $(0.25, 0.55, 0.80)$. We were willing to revise those policy values, but did not want to choose replacements merely to fit a preferred histogram. The companion paper *Calibrating PAIN Without Abandoning CVSS* documents the data-backed method used instead: define consequence anchors, exhaustively enumerate all 729 discrete impact/requirement states, and validate the result against anonymized operational datasets. An adopter SHOULD revalidate the governed values against its own rated findings rather than target a desired percentage in each word bucket. A CSP MAY adopt different thresholds based on its own documented risk evaluation, but the alternative SHOULD define its word semantics first, enumerate the supported state space, validate boundary consequences, disclose the active policy to affected agencies, and version the complete calibration. Thresholds MUST NOT be changed ad hoc after seeing a finding’s deadline. They should also remain independent of Certification Class: Class selects the response commitment after potential impact is derived.
3. **Compound impact is a proxy; CWE is not a PAIN input**. The reference θ_3 preserves at least one High-impact/High-requirement alignment and requires another High impact on a Moderate-or-High requirement. This is our auditable approximation that vulnerabilities capable of multidimensional loss belong in a broader consequence class before receiving the word Debilitating. It is not a CWE classifier. CWE is designed for weakness root-cause mapping, contains multiple abstraction levels, and can be missing, multiply mapped, or imprecise for a particular vulnerability. A provider-authored CWE-to-severity table would therefore add a large, contestable input with no stable precedence over observed CVSS impact. CWE MAY still support remediation ownership, secure-development analysis, detection planning, and finding grouping outside the PAIN calculation.
4. **EPSS Likely-Exploitable threshold** $\theta_{\text{epss}} = 0.50$. The EPSS probability at or above which a finding is treated as LEV (Section 9). This memo recommends 0.50 so vulnerabilities with at least an even predicted chance of exploitation enter the fast track; higher values produce fewer fast-track findings. FedRAMP leaves the framework to the provider.
5. **LEV is a union, not a blend**. A finding is Likely Exploitable if $\text{EPSS} \geq \theta_{\text{epss}}$, *or* it is listed in the CISA KEV catalog — whichever fires, with no weighting among them.
6. **Impact-only severity**. We use the CVSS-derived impact aggregate rather than computing the full Environmental Score; exploitability and reachability select the remediation column instead of influencing the PAIN row. Section 7.1 enumerates this choice and every downstream CVSS component the method omits.

7. **Likelihood-only partial mitigation may use a labeled PAIN proxy.** FedRAMP defines partial mitigation as reducing likelihood or PAIN, while its timeframe and reporting workflow expresses progress through lower N-ratings. Section 11.1 retains consequence PAIN and permits a separately labeled residual-response proxy for verified local likelihood reduction. The same mitigation may also update the separately required IRV/LEV column; both outputs carry common provenance and are disclosed as correlated expressions of one control, not independent reductions. This reconciliation is ours, not a FedRAMP formula, and the proxy needs governed, disclosed calibration before operational use.
8. **CISA Vulnrichment is deliberately excluded.** Two CISA Vulnrichment SSV values are natural candidate inputs: the exploitation state (as a LEV input) and the technical impact (as an impact floor). We adopt neither. The exploitation role is served by KEV membership — the instrument BOD 26-04 itself names — and a technical-impact floor is rejected because an opaque, externally-fixed impact floor cannot coexist with the evidence-based Modified C/I/A mitigation lever of Section 11: when a fixed floor and cited local evidence disagree, there is no principled precedence between them, and the Environmental layer already re-weights impact per deployment. EPSS and the KEV catalog remain the two governed threat inputs. An adopter MAY reintroduce enrichment sources, at its own risk of exactly that conflict.
9. **Modifications lower High to Low, never to None; evidence scales with the PAIN reduced.** The mitigation lever of Section 11 lets cited, signed evidence lower a Modified impact dimension, but never to None: a claim of *zero* impact is an applicability claim and must travel as a VEX disposition (Section 15), where it is separately governed, auditable, and reversible. And the evidence bar scales with the stakes — lowering an N5 to an N4 demands stronger corroboration than lowering an N2 to an N1, mirroring the disposition guardrails. Both rules are ours, not FedRAMP's; an adopter tightening or relaxing them SHOULD do so in governed configuration.
10. **Automatic high-availability credit is scoped by reachability.** Verified redundancy (replicas, required zone anti-affinity with observed spread, PodDisruptionBudget, automatic restart) applies MA High→Low automatically for findings that are *not* internet-reachable; internet-reachable findings take the step only with a per-finding citation explaining why the trigger cannot be repeated at line rate. Rationale: IRV means the attacker can re-deliver the exploit, and replication defends against uncorrelated failure, not a flaw every replica shares. An adopter MAY tighten this (citation everywhere) or, at its own risk, relax the reachability carve-out; either choice belongs in governed configuration with the residual documented.
11. **Scope is finding-specific; hierarchical metadata is the baseline.** Asset, containing-boundary, and provider-default tags resolve most-specific-first as the operational starting point. Evidence that a finding is tenant-contained can keep a shared asset single-agency; evidence that its effect traverses a shared control plane or dependency can establish multi-agency scope. There is no automatic per-archetype escalation and no generic scope multiplier. The affected-agency basis remains explicit and operator-controlled.
12. **The profile is required; an archetype is optional.** The formula ultimately requires a per-asset effective Security Requirements vector (CR/IR/AR); the upstream asset security-impact profile may come from direct per-objective assessment, an archetype catalog, or any governed classification scheme that maps deterministically to independently representable CR/IR/AR. No implementation is required to expose `asset-archetype` or any particular metadata key.

We recommend role-based archetypes as one strong derivation method because they provide granularity and a clear, auditable evidence chain. The same software can therefore land in different example archetypes by how it is used (an in-memory store is **app-tier** as a cache, **identity-secrets** as a session store, or **data-backbone** as a broker). A scalar asset-value label is permitted as shorthand but should not be the only interface because it collapses all objectives to one repeated value. If an adopter retains an archetype taxonomy, the role-not-software-kind semantics should be preserved.

13. **The intended-use ceiling is separate from the asset profile.** Equation (1) caps the asset’s system-relative profile by the confirmed, dimensional federal consequence of the affected agency scope. This lets one CSO reuse its profile derivation policy across agency deployments without pretending that agency information types are intrinsic properties of a component. The preferred derivation retains confirmed NIST SP 800-60 information types; the simpler $\min(\text{SSO}, \text{ASO})$ vector form is a documented approximation. An omitted ceiling preserves uncapped, conservative compatibility behavior but is not an evidenced agency-specific derivation.
14. **Fail-safe defaults to conservative High.** An unclassified asset defaults to CR/IR/AR all High so it scores loudly, rather than to a low default. “Unknown” is treated as serious until classified.
15. **CVSS v3.1, not v4.0.** We build on v3.1’s closed-form environmental formula because it provides a Modified Impact Sub-Score whose pre-cap expression is Eq. 2, with explicit CR/IR/AR multipliers. CVSS v4.0 retains CR/IR/AR but feeds them into a lookup-based MacroVector rather than the v3.1 formula, and it splits impact into Vulnerable-System (VC/VI/VA) and Subsequent-System (SC/SI/SA) metrics. A v4.0-only finding can use the limited compatibility mapping from VC/VI/VA onto C/I/A, but Subsequent-System metrics remain reviewable evidence and must not disappear from the derivation record. This memo does not define automatic multi-target aggregation. While NVD remains v3.1-dominant, an implementation SHOULD prefer the v3.1 vector when both are available.
16. **The example archetype-to-profile catalog and its CR/IR/AR values (Appendix A).** Illustrative only — each CSP SHOULD derive its security-impact profiles from component roles, trust, privilege, dependencies, data handling, and consequences inside its CSO architecture, then apply the separately governed intended-use ceiling. A 3PAO MAY take on the role of validating the derivation policy and assignments during an assessment; however, the CSP remains ultimately responsible if an asset profile is understated, a vulnerability is not remediated in time, and it is subsequently exploited (just as in the commercial world).
17. **The remediation deadline values (Appendix B) are *not* ours to calibrate.** They are reproduced verbatim from FedRAMP’s published VDR-TFR-PVR table (mandated by CISA BOD 26-04; see Section 13). The only provider-side choice is which Certification Class (A–D) the offering commits to, selecting the column block; the day counts themselves are fixed by FedRAMP. Listed here only to mark the boundary between what we chose and what the rule dictates.

Acknowledgements

While this paper has a single official author, the underlying work, refinement, and practical validation were a collaborative effort. It would not have been possible without the generous help, critical

feedback, and dedicated support of various other team members at stackArmor who helped make it possible.

Normative sources

- [VDR] FedRAMP, *Vulnerability Detection and Response (VDR)*. Requirements cited: VDR-TFR-PVR, VDR-TFR-KEV, VDR-TFR-PDD/PCD/PSD. Pinned permalink: FedRAMP/2026-markdown@2a75592 (commit of 2026-06-24; generated from upstream `fedramp/rules`). Accessed 2026-06-27.
- [VER] FedRAMP, *Vulnerability Evaluation and Reporting (VER)*. Requirements cited: VER-EVA-EIR, VER-EVA-EFP, VER-EVA-AIA, VER-RPT-VDT, VER-TFR-MAV, VER-RPT-AVI. Pinned permalink: FedRAMP/2026-markdown@2a75592 (commit of 2026-06-24). Accessed 2026-07-01.
- [DEF] FedRAMP, *FedRAMP Definitions*. Definitions cited: FRD-IRV, FRD-LEV, FRD-PAI, FRD-PMV, FRD-FMV, and FRD-RMV. Pinned permalink: FedRAMP/2026-markdown@2a75592 (commit of 2026-06-24). Accessed 2026-07-01.
- [EGR] M. Venne, *Internet Reachability at Scale under the FedRAMP VDR/VER Rules*, stackArmor, July 2026. Companion paper specifying the reachability determination used here.
- [CEILING] M. Venne, *Before the PAIN Equation: Deriving Security-Requirements Ceilings from Intended Federal Information Types*, stackArmor, July 2026. Upstream derivation of effective CR/IR/AR.
- [FIPS199] National Institute of Standards and Technology, *Standards for Security Categorization of Federal Information and Information Systems*, FIPS PUB 199, February 2004.
- [SP800-60] National Institute of Standards and Technology, *Guide for Mapping Types of Information and Information Systems to Security Categories*, SP 800-60 Volumes I and II, Revision 1, August 2008.
- [BOD] CISA, *Binding Operational Directive 26-04*, 2026-06-10.
- [KEV] CISA, *Known Exploited Vulnerabilities (KEV) Catalog*. LEV input; VDR-TFR-KEV schedule.
- [CVSS] FIRST, *CVSS v3.1 Specification* — Environmental metric group and Modified Impact Sub-Score.
- [CVSS40] FIRST, *Common Vulnerability Scoring System v4.0: Specification Document*. Vulnerable- and Subsequent-System impact metrics. <https://www.first.org/cvss/v4.0/specification-document>.
- [CVSS40-UG] FIRST, *CVSS v4.0 User Guide*. Vulnerable-System and Subsequent-System boundary guidance, including the SQL-injection example. <https://www.first.org/cvss/user-guide.html>.
- [EPSS] FIRST, *Exploit Prediction Scoring System*.
- [CLASS] FedRAMP, *Choosing a Certification Class*, Consolidated Rules for 2026. <https://www.fedramp.gov/2026/providers/start/class/#alignment-with-agency-use-cases>.

[IEC] FedRAMP, *Incident Evaluation and Communication*, Consolidated Rules for 2026. <https://www.fedramp.gov/2026/providers/20x/rules/incident-evaluation-and-communication/>.

[CWE-RCM] MITRE, *CVE to CWE Root Cause Mapping Guidance*. https://cwe.mitre.org/documents/cwe_usage/guidance.html.